JÖNKÖPING UNIVERSITY
School of Engineering

Encryption

Lecture 7, Information Security, 7,5 ECTS

Björn Praestegaard Larsen
bjorn.larsen@ju.se

Overview of lecture 8

- Terminology
- Symmetric cryptosystems
- Asymmetric cryptosystems
- DES
- AES
- RSA
- Key exchange
- Error detecting codes
- Shannon’s characteristics of good ciphers

Introduction

- Cryptography (from ancient Greek: hidden/secret and write) conceals data against unauthorized access
- Cryptography is the go-to security control for handling many kinds of security threats
- Cryptography address core security failures:
  - Encrypted data cannot be read, modified, or fabricated easily
- Cryptography is rooted in higher mathematics:
  - Group theory, field theory, computational complexity, probability, statistics…
  - But we do not need to understand all underlying mathematics to be able to use cryptography!

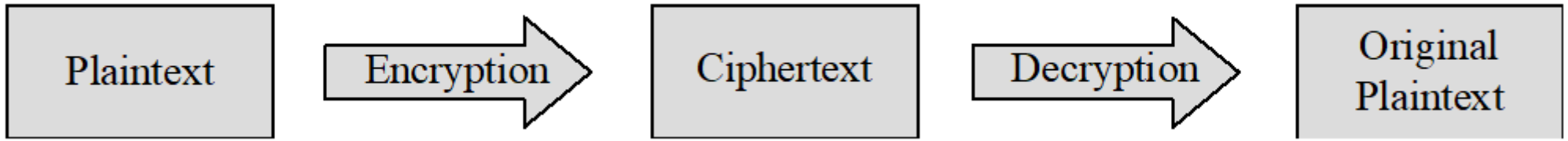
Terminology

- Cryptanalysis: the study of methods for breaking ciphertext
- Cryptography and cryptology are sometimes used interchangeably, but…
  - Cryptography: the use and practice of cryptographic techniques
  - Cryptology: the study of both cryptography and cryptanalysis

- Encrypt/encode/encipher: is the process of encoding a message so that its meaning is not obvious
- Decrypt/decode/decipher: is the reverse process, transforming an encrypted message back into its normal, original form

Terminology

- Plaintext/cleartext, P: the original form of a message
- Ciphertext/cyphertext, C: encrypted version of a message
- Cipher: a pair of cryptographic algorithms, e.g., a mathematical function used for encryption and one for decryption

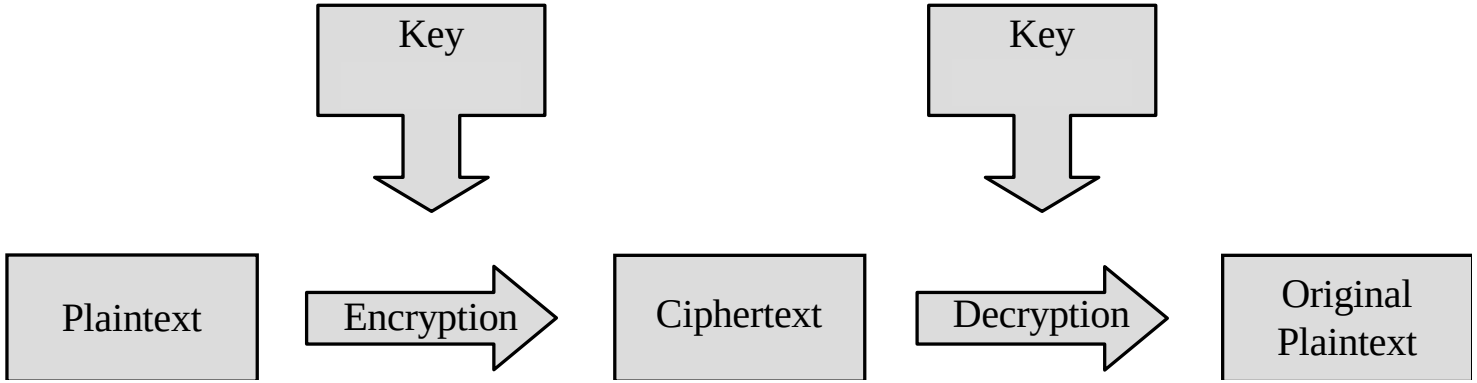


Terminology

- A plaintext message, P, can be seen as a sequence of individual characters:
  - $P = <p_1, p_2, \ldots, p_n>$
- Hence, a ciphertext message, C, can be seen as :
  - $C = <c_1, c_2, \ldots, c_n>$
- If we use formal notation for the encryption, E, and decryption, D, we can write:
  - C = E(P) (a chiphertext = encryption rule applied on a plaintext message)
  - P = D(C)
- A cryptosystem is: P = D(E(P))
  - We want to be able to convert the message to protect it from an intruder, but we also want to be able to get the original message back so that the receiver can read it properly

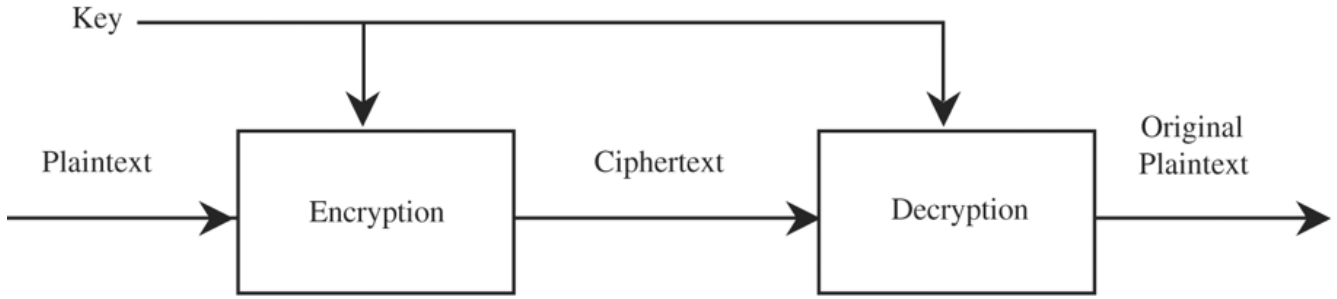
Encryption algorithms

- The cryptosystem involves a set of rules for how to encrypt the plaintext and how to decrypt the ciphertext
- The encryption and decryption rules (algorithms) use a key, K, so that the resulting ciphertext depends on the original plaintext message, the algorithm, and the key-value:
  - C = E(K, P)



Encryption algorithms

- We use well-established, well-examined algorithms with different keys
  - Similar to key usage for houses, same vendors, locks – just different keys!
- Symmetric cryptosystem - encryption and decryption keys are the same:
  - C=E(K,P)
  - P=D(K,C)
  - Or P = D(K, E(K,P))
    - Symmetric because D and E are mirror-image processes
  - Also called single-key or secret key

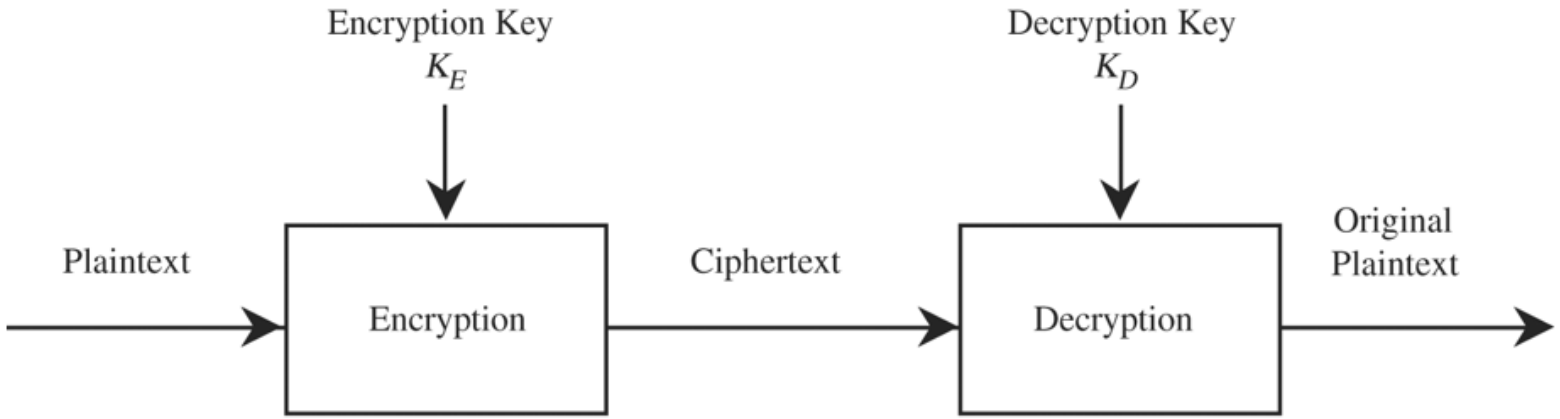


Symmetric cryptosystems

- Encryption and decryption keys are the same
- Provide a two-way channel to their users
- If the key is kept secret for a pair - the system also provides authentication proof
- If the secret key is compromised, the adversary can decrypt all traffic and produce fake messages
- Also, there is a key distribution problem
  - How do A and B obtain their shared secret key?
  - In general, n users who want to communicate in pairs need:
    - n * (n - 1)/2 keys

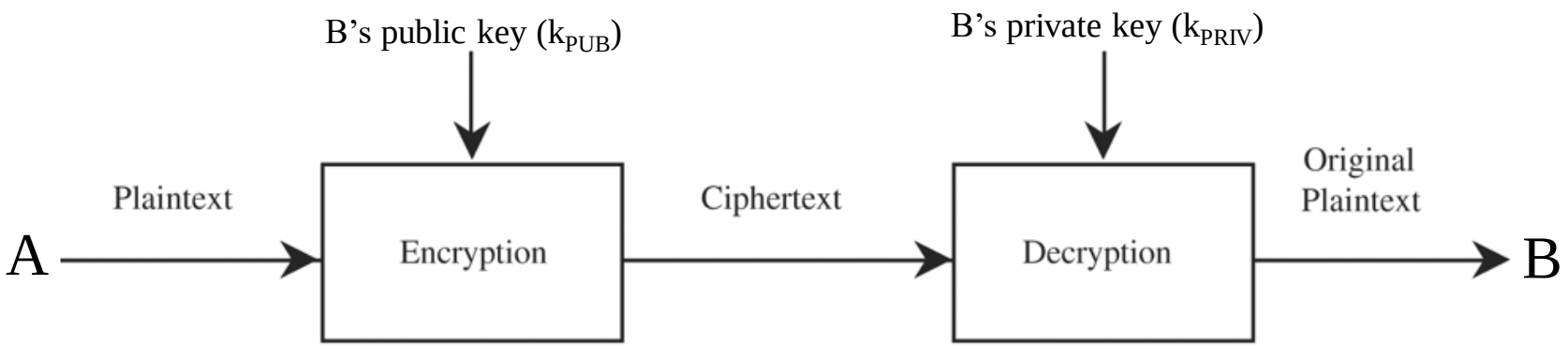
Asymmetric cryptosystem

- One key for encryption and another key for decryption
  - Keys come in pairs
  - A decryption key, K_D, inverts the encryption of key K_E so that:
  - $P = D(K_D, E(K_E,P))$
  - Also called public key
- Much slower than symmetric cryptosystems!



Asymmetric cryptosystems

- The keys operate as inverses
  - Let k_{PRIV} be a user's private key
  - Let k_{PUB} be the corresponding public key
- To encrypt, one key is used, and to decrypt the other key is used
  - So, if A wants to send to B
  - A will use k_{PUB} from B to encrypt, and
  - B will use its k_{PRIV} to decrypt (in this case, A cannot decrypt what it just encrypted)



Asymmetric cryptosystems

- With the asymmetric or public key approach, the key is really “public”
  - No problem to send in an e-mail or post it in public!
  - The private key must, of course, be kept private
  - Keys are in pairs, and the keys are linked together but cannot be mathematically extracted from each other (impossible to find the private key if the public is known)

- Asymmetric encryption is used in e.g., RSA (Rivest–Shamir–Adleman)… and it give us confidentiality, authenticity, and non-repudiability

- … and of course, we need to keep our private key private…

Stream and block ciphers

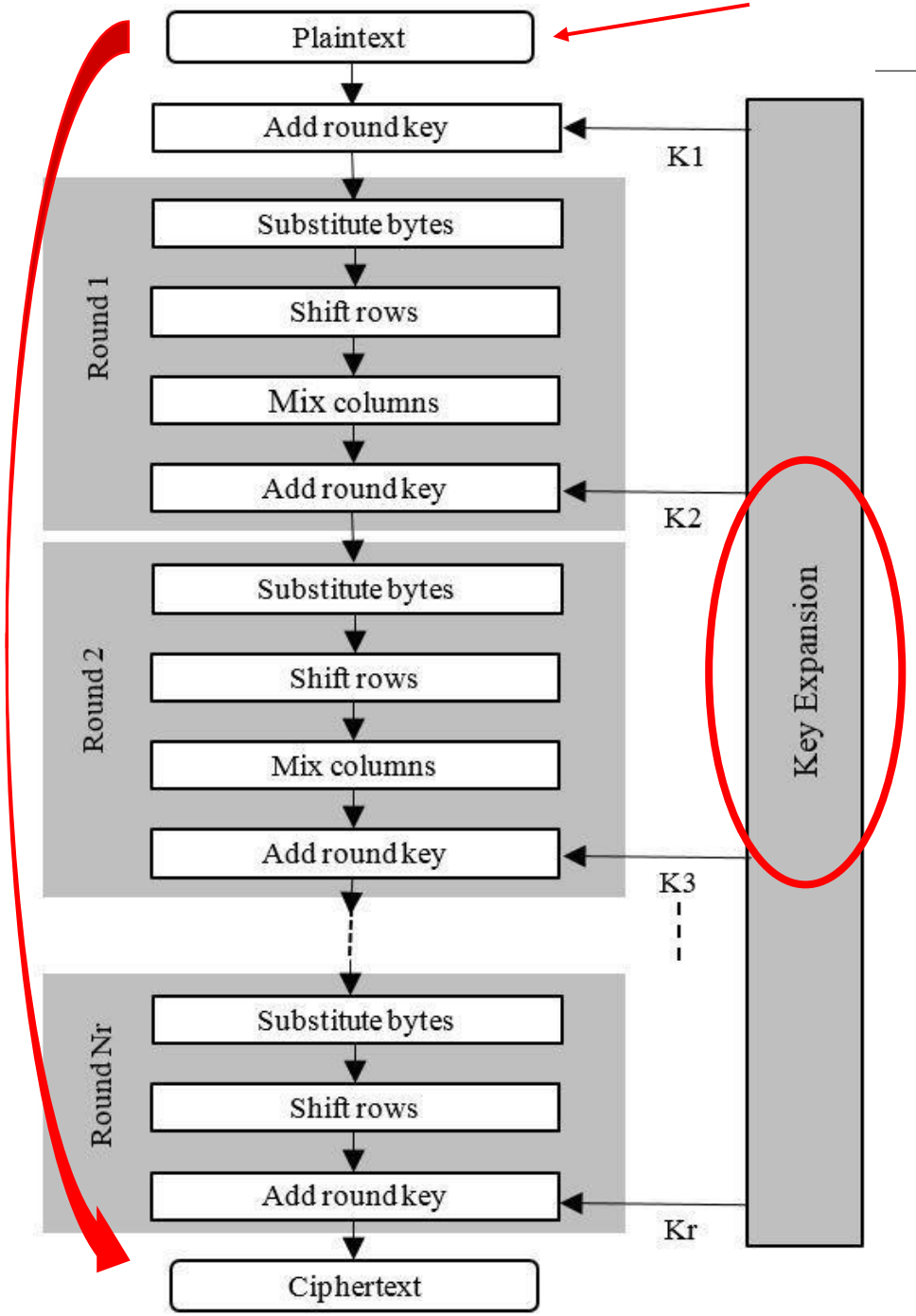
- Stream
  - Each bit/byte of the data stream is encrypted separately (low diffusion)
  - Fast and encryption can take place as soon as data is read
  - If errors occur, only bit/byte is affected
  - Susceptible to malicious insertions and modifications
- Block
  - Encrypts a group of plaintext symbols as a single block (typically 64, 128, 256 bits or more) (high diffusion)
  - Slower process, the last block needs to be padded, and an error affects more bytes
  - Impossible to insert a single symbol into one block

The Data Encryption Standard (DES)

- Symmetric block cipher
- Developed in 1976 by IBM for NIST (with NSA approval), and became widely adopted
- Encryption and decryption algorithms are public but the design principles are classified (backdoor for NSA?)
- Used fixed 56 bits (short) key (tough enough for most but easy for NSA?)
- In 1999, a DES key was brute-forced in 22 hours and 15 minutes
- Solution: DES multiple encryption: Double DES, Triple DES (3DES)
- But… even 3DES is considered insecure and was deprecated by NIST in 2017

Advanced Encryption Standard (AES)

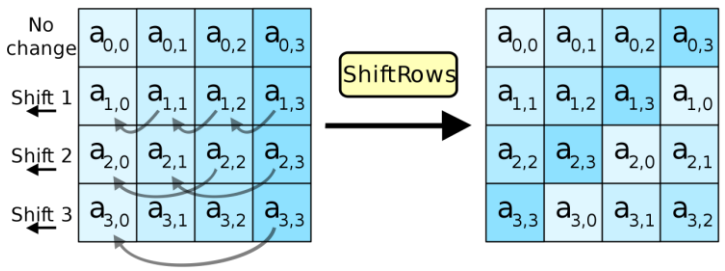
- It started as a public call from NIST for a replacement to DES in 1997
  - Rijndael from Vincent Rijmen and Joan Daemen won as it was considered secure enough (expected to live for 20-30 years), high performance, efficient, easy to implement…
  - Became AES in 2001
- Symmetric, block cipher (128 bits)
- Three different key lengths: 128, 192, and 256 bits
- No relation to a government agency
- Has a sound mathematical foundation
- Became a FIPS standard (to be used by U.S. Government organizations)
- It is the de-facto standard for the world today – and still considered secure enough!
  - Used in e.g., WPA2, IPsec, WhatsApp, Telegram… and in hardware such as Intel & AMD processors

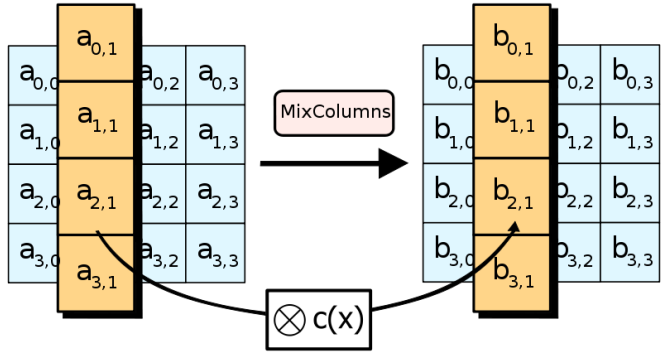


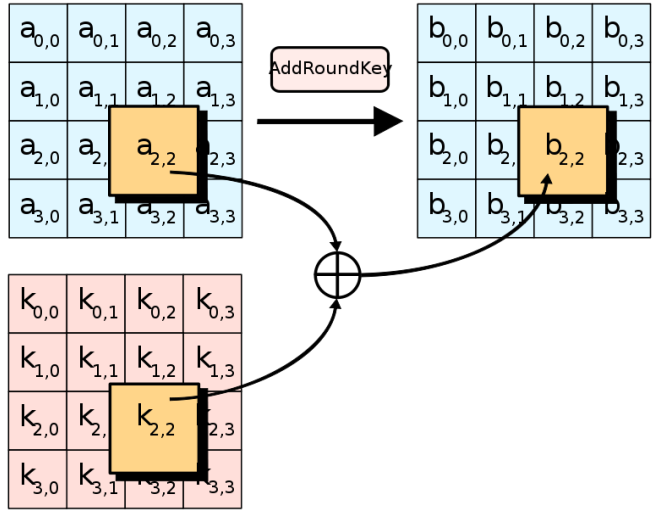
AES Substitution box

	00	01	02	03	04	05	06	07	08	09	0a	0b	0c	0d	0e	0f
00	63	7c	77	7b	f2	6b	6f	c5	30	01	67	2b	fe	d7	ab	76
10	ca	82	c9	7d	fa	59	47	f0	ad	d4	a2	af	9c	a4	72	c0
20	b7	fd	93	26	36	3f	f7	cc	34	a5	e5	f1	71	d8	31	15
30	04	c7	23	c3	18	96	05	9a	07	12	80	e2	eb	27	b2	75
40	09	83	2c	1a	1b	6e	5a	a0	52	3b	d6	b3	29	e3	2f	84
50	53	d1	00	ed	20	fc	b1	5b	6a	cb	be	39	4a	4c	58	cf
60	d0	ef	aa	fb	43	4d	33	85	45	f9	02	7f	50	3c	9f	a8
70	51	a3	40	8f	92	9d	38	f5	bc	b6	da	21	10	ff	f3	d2
80	cd	0c	13	ec	5f	97	44	17	c4	a7	7e	3d	64	5d	19	73
90	60	81	4f	dc	22	2a	90	88	46	ee	b8	14	de	5e	0b	db
a0	e0	32	3a	0a	49	06	24	5c	c2	d3	ac	62	91	95	e4	79
b0	e7	c8	37	6d	8d	d5	4e	a9	6c	56	f4	ea	65	7a	ae	08
c0	ba	78	25	2e	1c	a6	b4	c6	e8	dd	74	1f	4b	bd	8b	8a
d0	70	3e	b5	66	48	03	f6	0e	61	35	57	b9	86	c1	1d	9e
e0	e1	f8	98	11	69	d9	8e	94	9b	1e	87	e9	ce	55	28	df
f0	8c	a1	89	0d	bf	e6	42	68	41	99	2d	0f	b0	54	bb	16

9c=>de







Rivest-Shamir-Adelman (RSA)

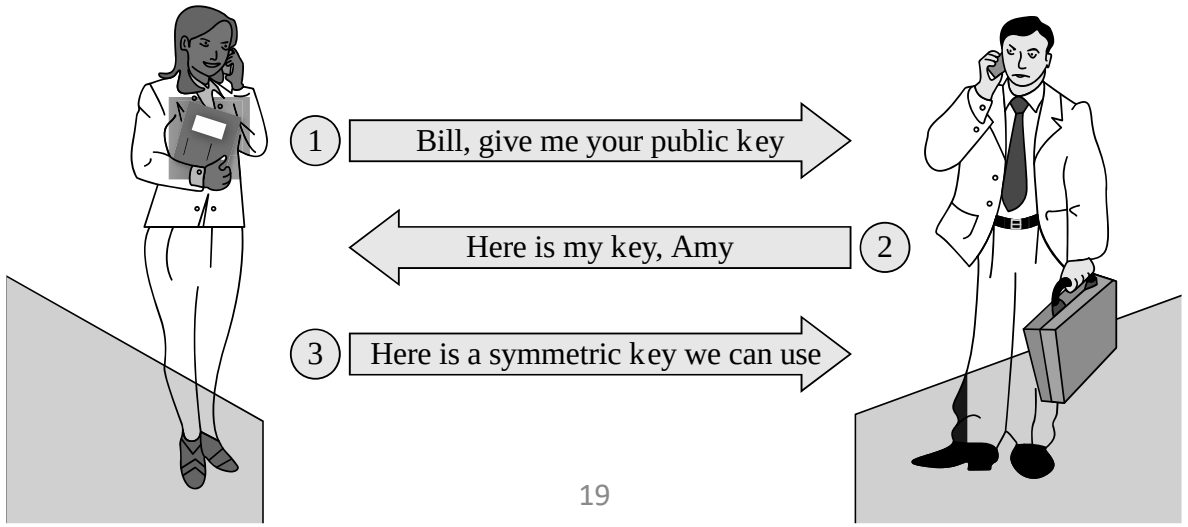
- Asymmetric block cipher
- Public key system (i.e., one private and one public key)
- Long keys (1024-4096 bits)
- RSA has been the subject of extensive cryptanalysis, but still no serious flaws
- Slow algorithm

Symmetric vs. asymmetric encryption

	Secret Key (Symmetric)	Public Key (Asymmetric)
Number of keys	1	2
Key size (bits)	56–112 (DES), 128–256 (AES)	Unlimited; typically no less than 256; 1000 to 2000 currently considered desirable for most uses
Protection of key	Must be kept secret	One key must be kept secret; the other can be freely exposed
Best uses	Cryptographic workhorse. Secrecy and integrity of data, from single characters to blocks of data, messages and files	Key exchange, authentication, signing
Key distribution	Must be out-of-band	Public key can be used to distribute other keys
Speed	Fast	Slow, typically by a factor of up to 10,000 times slower than symmetric algorithms

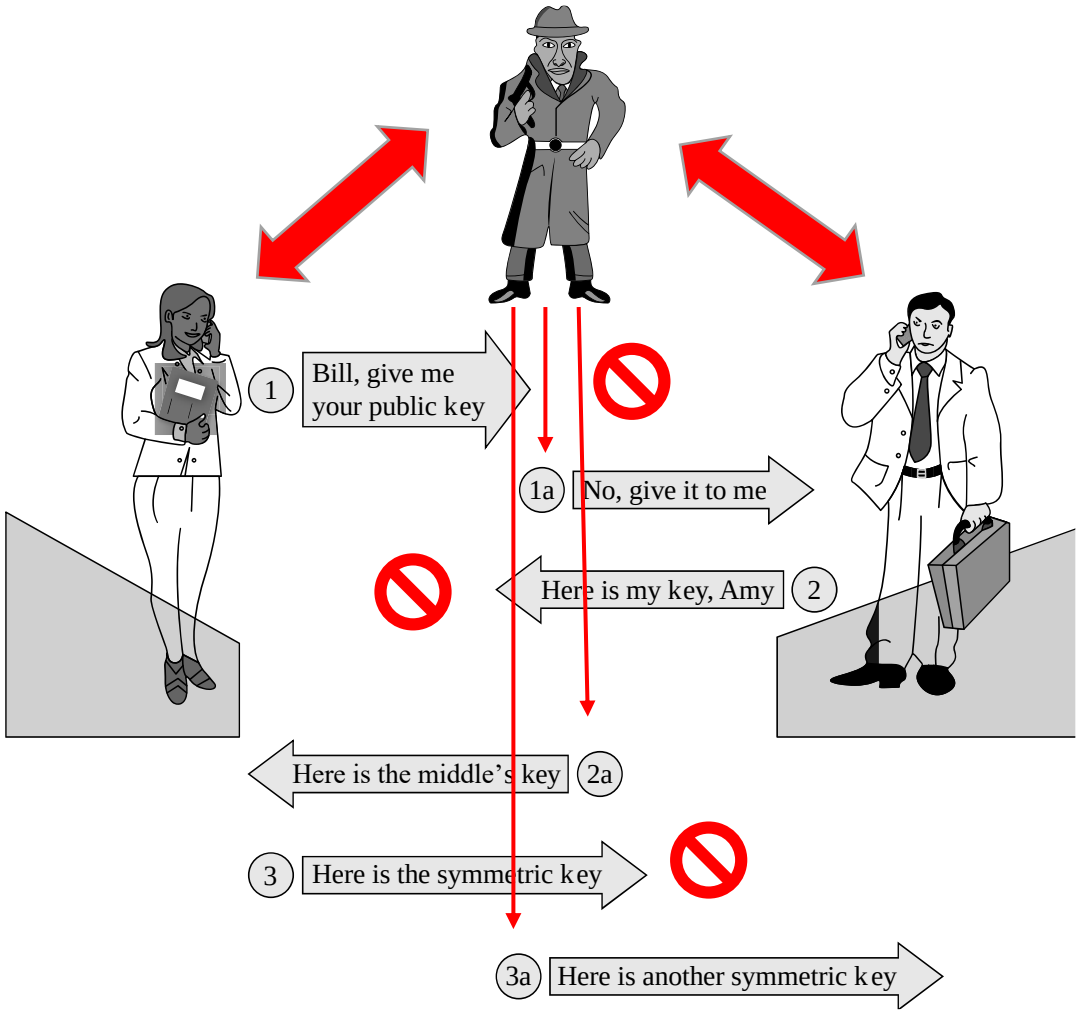
Public key to exchange secret keys

- So, we want fast, symmetric encryption, but we have a key distribution problem!
  - We need a secure and reliable channel for the shared key exchange
  - Important for sharing a secret message with someone you have not shared messages with before (e.g., between two computers on the Internet)
  - Let's use the public key (asymmetric) for exchanging the symmetric keys!



Problem?

- Same as previous, but man-in-the-middle
- We need a way to exchange keys without an adversary learning it

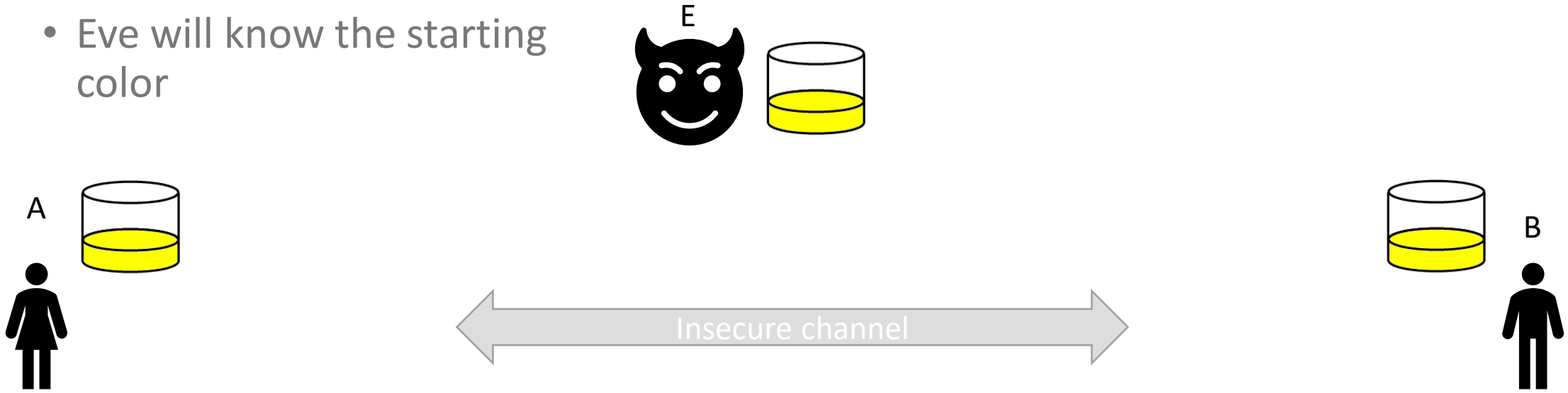


Diffie-Hellman key exchange

- The Diffie-Hellman key exchange protocol offers a way in which a public channel can be used to create a confidential shared key
- Builds on modulo exponentiation, prime numbers…
- It can be visualized by a paint-mixing example
  - Based on two assumptions:
    - Paint is easy to mix
    - Paint is hard to unmix

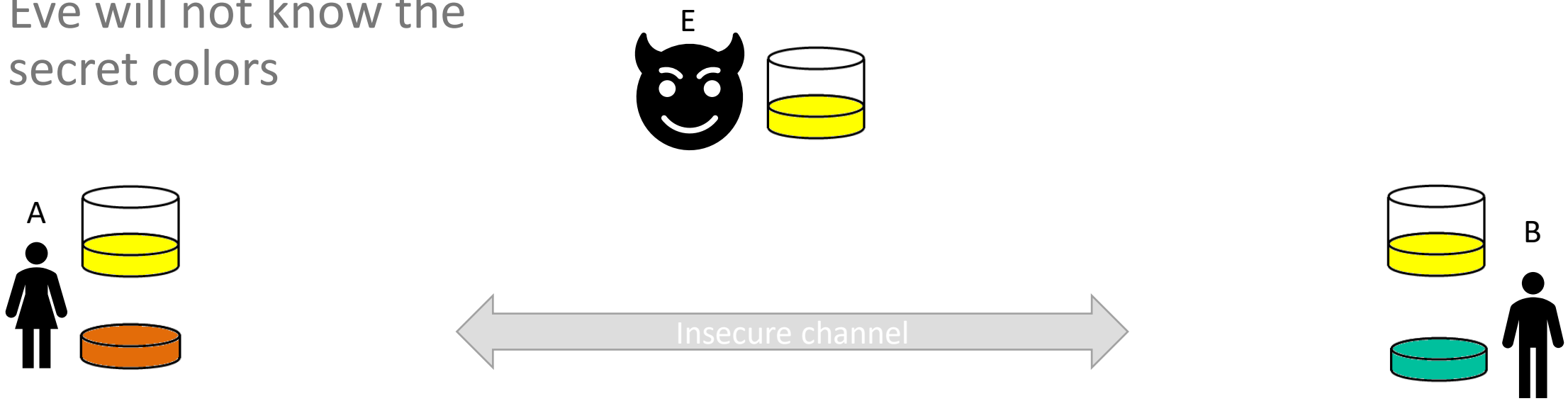
Diffie-Hellman key exchange (1)

- Agree publicly on an arbitrary starting color
  - It does not need to be kept secret
  - But it should be different every time
  - Eve will know the starting color



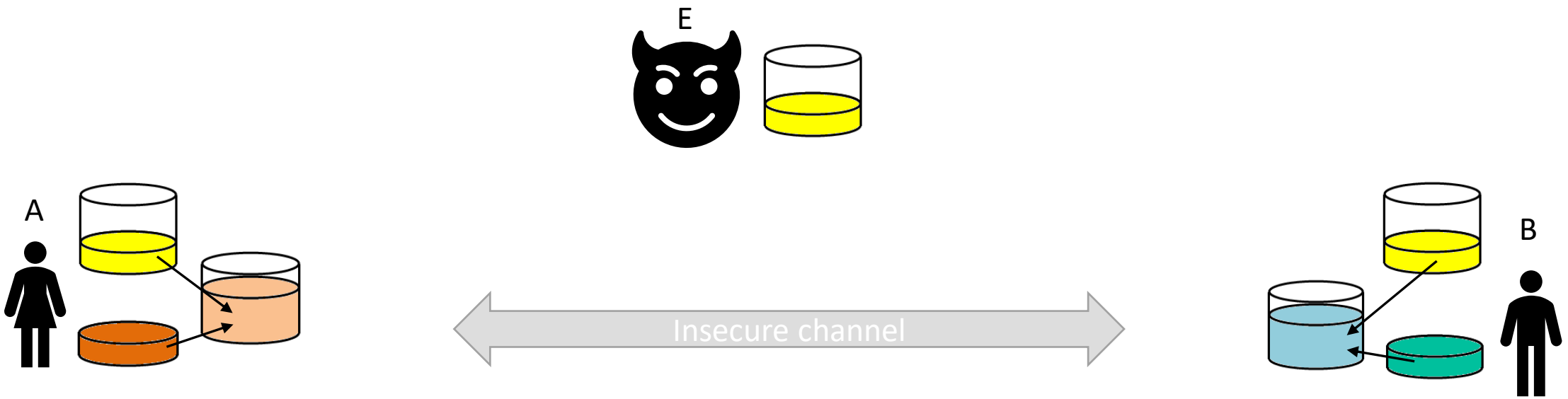
Diffie-Hellman key exchange (2)

- Pick a private color (Alice and Bob)
- Secret colors not shared - neither knows of the other's secret
- Eve will not know the secret colors



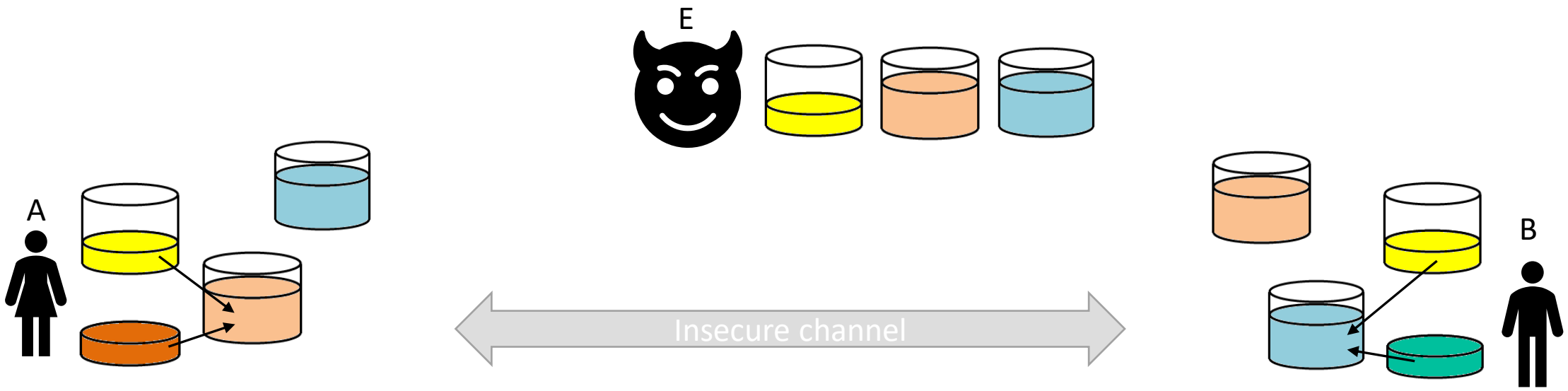
Diffie-Hellman key exchange (3)

- Mix the (public) starting color with the secret color



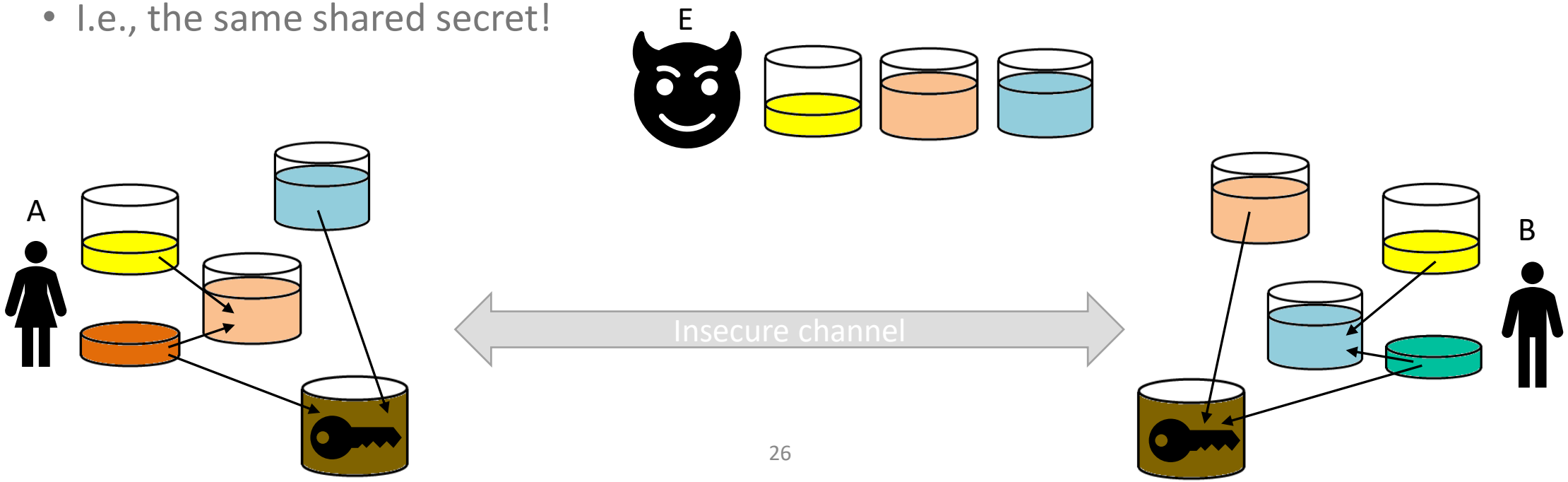
Diffie-Hellman key exchange (4)

- Exchange the mixed colors with each other
- Eve will learn both the mixed colors

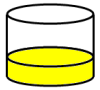
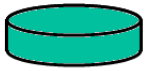
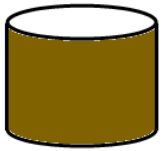
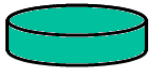
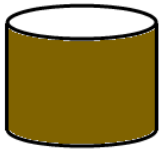


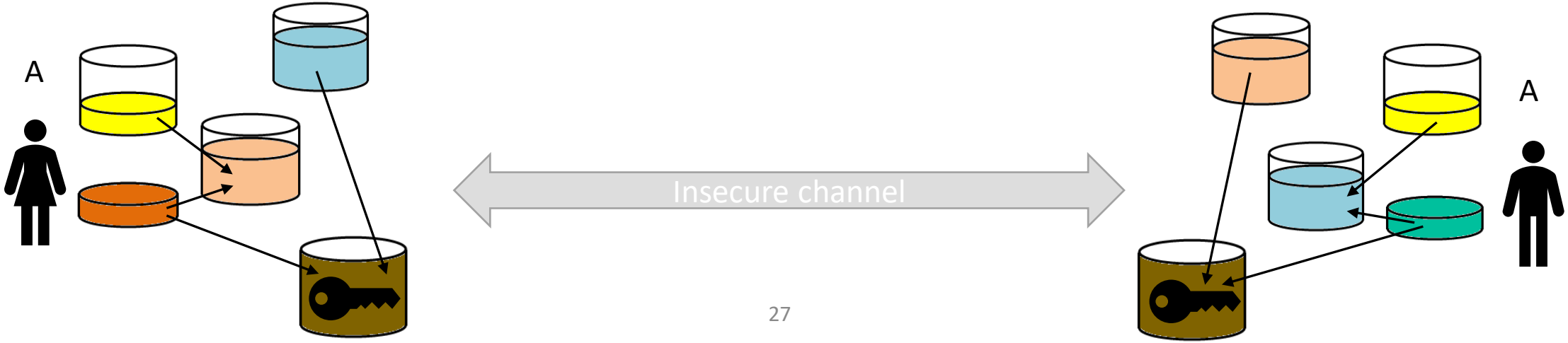
Diffie-Hellman key exchange (5)

- Now the magic happens – mix the others shared color with their own secret color
- This produces a new and identical mixture for each!
  - I.e., the same shared secret!



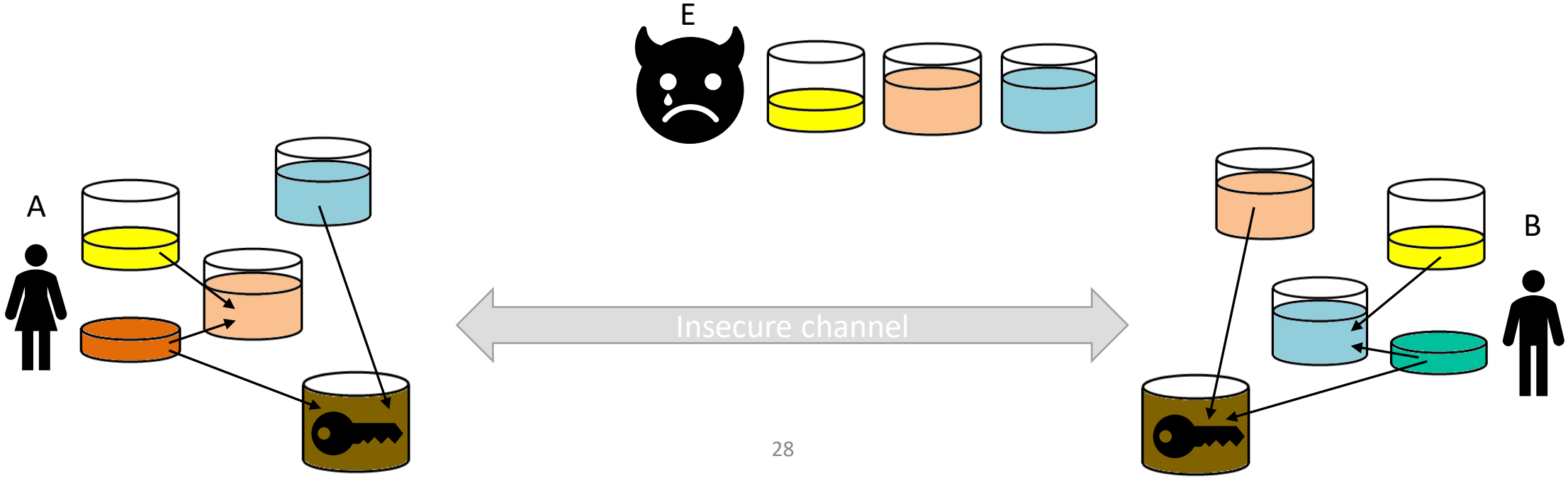
Diffie-Hellman key exchange

- How come they are identical?
  - A mixed: ( +  from B) + = 
  - B mixed: (+ from A) +  = 



Diffie-Hellman key exchange

- What about Eve?
  - No knowledge of the secret colors of either A or B
  - Unmixing a color is very difficult



Error detecting codes

- Errors in transmission happen, and we need a fast and reliable way of finding out
- Also, sometimes integrity is more important or as important as confidentiality
- We use different names: hash codes, message digests, checksums, integrity checks, error detection, and correction codes…
  - Demonstrates that a block of data has been modified
- Simple error detecting codes:
  - Parity checks
  - Cyclic redundancy checks
- Cryptographic error detecting codes:
  - One-way hash functions
  - Cryptographic checksums
  - Digital signatures

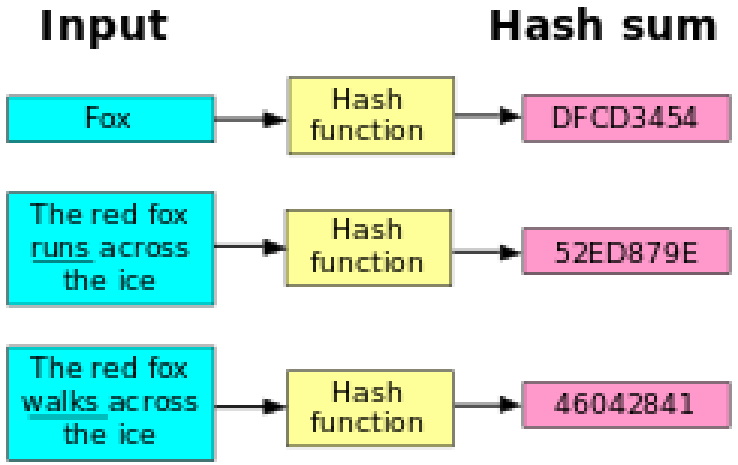
Parity check and cyclic redundancy check

- A parity bit is the simplest form of detection code:
  - Add an extra bit to a group of bits
  - Even and odd parity
  - For even parity:
    - For a given set of bits, the bits whose value is 1 are counted. If the count is odd, the parity bit value is set to 1
- Cyclic redundancy check (CRC):
  - Simple to implement in hardware
  - Used for Ethernet, most telecom (mobile networks…)…

Original Data	Parity Bit	Modified Data	Modification Detected?
0 0 0 0 0 0 0 0	1	0 0 0 0 0 0 0 1	Yes
0 0 0 0 0 0 0 0	1	1 0 0 0 0 0 0 0	Yes
0 0 0 0 0 0 0 0	1	1 0 0 0 0 0 0 1	No
0 0 0 0 0 0 0 0	1	0 0 0 0 0 0 1 1	No
0 0 0 0 0 0 0 0	1	0 0 0 0 0 1 1 1	Yes
0 0 0 0 0 0 0 0	1	0 0 0 0 1 1 1 1	No
0 0 0 0 0 0 0 0	1	0 1 0 1 0 1 0 1	No
0 0 0 0 0 0 0 0	1	1 1 1 1 1 1 1 1	No

Hash functions

- A (good) hash function should:
  - Easily compute the hash value for any given message
  - Have a one-way property (infeasible to find a message that has a given hash)
  - Make it infeasible to modify a message without changing its hash
  - Make it infeasible to find two different messages with the same hash
- We use hash for many reasons:
  - Message integrity
  - Message authentication (hash is signed)
  - Protect password files
  - …

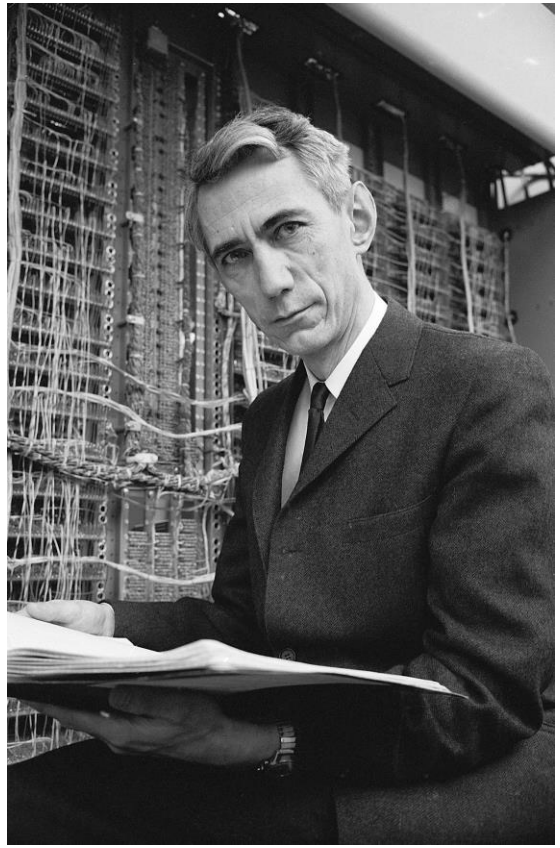


Cryptographic checksums

- Like putting a seal around a message/file – detect when the seal is broken
- An input of arbitrary length
- Fixed output size
- Allow for verification of the integrity of a file/message
- Well-known algorithms include:
  - Message Digest: MD2,MD4,MD5 (128b hashed value) – insecure
  - Secure Hash Algorithm: SHA0 (160b) – insecure
  - SHA1 (160b) – may be insecure (at least theoretically)
  - SHA-2, SHA-3 (256, 512, 1024b) – Good for us ☺

Shannon's characteristics of good ciphers

- Formulated in 1949 by Claude Shannon!
- The amount of secrecy needed should determine the amount of labor appropriate for the encryption and decryption
  - Questions such as key length,… based on the implementation of the algorithm, current and predicted speeds of computers, and resources of likely attackers…
- The set of keys and the enciphering algorithm should be free from complexity
  - The process must work on plaintext input, and keys should be easy for users to generate, transmit, and store.
  - If the process is too complex, it will not be used



Shannon's characteristics of good ciphers

- The implementation of the process should be as simple as possible
  - Complexity is the enemy of good security analysis
  - A simpler algorithm is more likely to be free of flaws
- Errors in ciphering should not propagate and cause corruption of further information in the message
  - Communication errors do happen, and when they do, the need for retransmission should be as limited as possible.
- The size of the enciphered text should be no larger than the text of the original message
  - Ciphertext that expands dramatically in size cannot carry more information than the plaintext
  - It gives the cryptanalyst more data from which to infer a pattern
  - Longer ciphertext implies more space for storage and more time to communicate

JÖNKÖPING UNIVERSITY

School of Engineering